

Informe SOC

Laboratorio de detección de amenazas con Wazuh (SIEM)

Autor: Daniel B.L. Fecha : 1 de septiembre de 2026

1. Resumen

Realizé un ejercicio de laboratorio en un entorno controlado para probar la capacidad de detección de Wazuh. Desde una máquina Kali Linux se hizo un escaneo de puertos con Nmap y, después un ataque de fuerza bruta por SSH con Hydra a mi equipo Ubuntu Desktop monitorizado por Wazuh agent. Las actividades fueron detectadas y vigiladas por Wazuh Manager, generando alertas y disparando una regla de detección personalizada creada específicamente para esta prueba.

2. Fecha y hora

Inicio: 1 de septiembre de 2026 a las 23:27 - escaneo con Nmap.

Fin: 1 de septiembre de 2026 a las 23:35 - ataque de fuerza bruta con Hydra.

3. Origen

Host atacante: Kali Linux, IP 192.168.1.55. Utilizando las herramientas Nmap (para escaneo de puertos) y Hydra (para fuerza bruta SSH en este caso con diccionario rockyou.txt, y usuario admin).

4. Destino

Host objetivo: Ubuntu Desktop (agente Wazuh registrado como danielsoc1), IP 192.168.1.54. Servicio afectado: SSH (puerto 22). El escaneo con Nmap se realizó sobre todos los puertos (-p-) del host.

5. Detección

Wazuh Manager desplegado en Ubuntu Server, con agente instalado en el equipo Ubuntu Desktop objetivo. Se crearon dos reglas personalizadas en `local_rules.xml`: la regla 100050 (nivel 3) detecta bloqueos de UFW (UFW BLOCK), y la regla 100051 (nivel 10, frequency=5, timeframe=60s), que se dispara cuando la regla 100050 se repite 5 veces en 60 segundos, generando la alerta "UFW: Escaneo de puertos o ataque de fuerza bruta detectado".

6. Evidencias

- Logs UFW (kernel) en el host objetivo, mostrando paquetes auditados y bloqueados (UFW AUDIT / UFW BLOCK) procedentes de 192.168.1.55.
 - Logs de autenticación SSH (sshd-session) con varias entradas "Failed password for invalid user admin from 192.168.1.55".
 - Panel Discover de Wazuh con 222 hits en la ventana 23:30–23:35, mostrando el pico de eventos coincidente con la ejecución de Hydra.
 - Alertas de nivel 10 ("User missed the password more than one time") y nivel 5 ("Attempt to login using a nonexistent user") asociadas al agente 192.168.1.54.
 - Código fuente de las reglas personalizadas (`local_rules.xml`, reglas 100050 y 100051).
-

7. Timeline

Hora	Evento	Fuente	Interpretación
23:27	Inicio de escaneo de puertos con Nmap (-p-) contra 192.168.1.54	Terminal Kali / logs UFW	Reconocimiento inicial: identificación de puertos abiertos
23:27–23:28	UFW registra paquetes desde 192.168.1.55	syslog kernel (UFW)	El firewall detecta y bloquea parte del tráfico de escaneo
23:34	Inicio de ataque de fuerza bruta SSH con Hydra	Terminal Kali	Intento de acceso no autorizado por fuerza bruta
23:35	Múltiples eventos "Failed password for invalid user admin" desde 192.168.1.55	sshd-session	Confirmación de intentos de autenticación fallidos masivos
23:35	222 alertas generadas en Wazuh (niveles 5 y 10) para el agente 192.168.1.54	Wazuh Discover	Detección automática del ataque.

8. Análisis L1

La secuencia de eventos es consistente con un ataque en dos fases típico de una intrusión: primero reconocimiento (escaneo de puertos con Nmap para mapear servicios expuestos) y después explotación por fuerza bruta (Hydra contra el servicio SSH identificado). El volumen y la frecuencia de los intentos fallidos de autenticación, concentrados en una ventana muy corta de tiempo desde una única IP origen, descartan un error de usuario legítimo y son característicos de una herramienta automatizada de fuerza bruta.

9. IOC

IP origen: 192.168.1.55. Usuario objetivo: admin. Puerto/servicio: 22/SSH (también se registró tráfico UDP/123 durante el escaneo). Patrón de log: "Failed password for invalid user admin from 192.168.1.55".

10. Impacto

Como lo hice en un laboratorio controlado, no hubo impacto real. En un escenario real, un ataque así podría haber derivado en acceso no autorizado al admin si la contraseña del usuario objetivo hubiera estado presente en el diccionario utilizado.

11. Severidad

Alta, la combinación de escaneo de puertos seguido de fuerza bruta contra el servicio SSH representa un patrón de ataque de alto riesgo si no se detecta y se para a tiempo.

12. Falso positivo

No. La actividad fue generada intencionadamente como parte del ejercicio (Nmap y Hydra lanzados de forma controlada desde Kali Linux) y las alertas se corresponden exactamente con el tráfico y los intentos de autenticación reales producidos durante la prueba.

13. Acción inmediata

Como analista L1: verificar el origen del tráfico (192.168.1.55) y confirmar que corresponde al ejercicio autorizado; revisar si existieron autenticaciones exitosas durante o después de los intentos fallidos; documentar la alerta con los IOC identificados; en un entorno real, bloquear la IP origen a nivel de firewall/UFW de forma inmediata si el bloqueo automático no lo hizo ya.

14. Escalado

No procede en este ejercicio, al tratarse de un laboratorio controlado sin impacto confirmado. En un entorno de producción, se escalaría a un analista L2 únicamente si se confirmara una autenticación exitosa tras los

intentos de fuerza bruta, o si el origen del ataque proviniera de una IP externa no perteneciente a la organización.

15. Recomendación

Implementar respuesta activa en Wazuh para bloquear automáticamente la IP origen tras superar el umbral de la regla 100051, reduciendo el tiempo de contención. Añadir una regla de correlación específica para los eventos SSH de fuerza bruta independiente del bloqueo de UFW, de forma que la detección no dependa únicamente del firewall. A nivel preventivo, restringir el acceso SSH por IP de origen y reforzar la política de contraseñas o migrar a autenticación por clave pública.
